

Clase 8

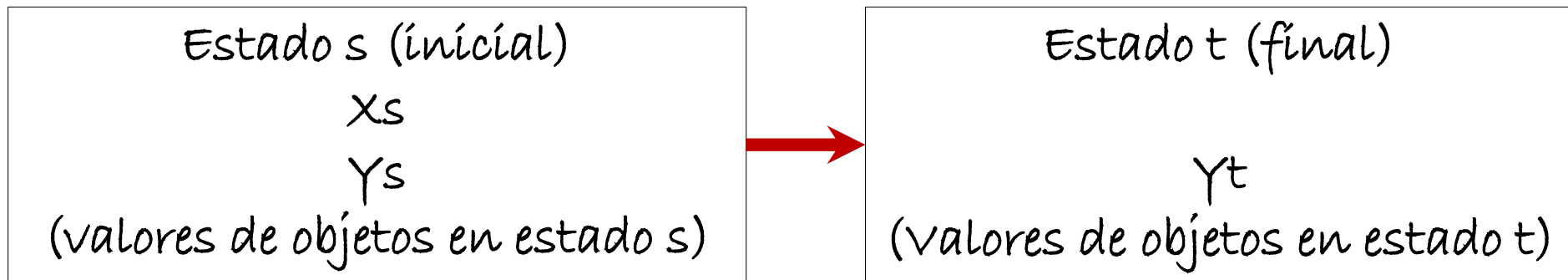
18 de mayo
de 2026

Principios de Diseño Seguro

1. Mínimo privilegio (Least privilege)
2. Valores por defecto seguros (Fail safe defaults)
3. Mecanismos simples (Economy of Mechanism)
4. Mediación completa (Complete Mediation)
5. Diseño abierto (Open Design)
6. Separación de tareas (Separation of privilege)
7. Mecanismos exclusivos (Least Common Mechanism)
8. Mínimo asombro = Aceptación psicológica (Least astonishment)

Flujo de Información

Hay flujo de información de un objeto x a un objeto y
sí la aplicación de una secuencia de comandos
hace que la información en x afecte a la información en y



Se mide con: **Entropía**

Entropía $H(x)$

- Cantidad de bits necesarios para codificar x
- Cantidad de información que hay en x

⇒ Mide INCERTIDUMBRE

> entropía → > incertidumbre

< entropía → < incertidumbre

$H(x) = 0 \rightarrow$ CERTEZA

Hay flujo de información cuando:

- $H(x_s | y_s) > H(x_t | y_t)$
- $H(x_s) > H(x_t | y_t)$

Fórmulas de Entropía

$$H(x) = - \sum p(x_i) \log_2(p(x_i))$$

$$H(x|y) = - \sum_{i=1}^L p(y_i) \left[\sum_{j=1}^N p(x_j|y_i) \log_2(p(x_j|y_i)) \right]$$

Ejemplo de Entropía

- Sea X variable que representa tirada de un dado azul
- Sea Y variable que representa suma de tiradas de dado azul y dado rojo
- Calcular $H(X|Y)$

$$p(X = x_j) = \frac{1}{6} \forall j$$

$$p(Y = y_i) = p(Y = 2) \cup p(Y = 3) \dots = \left\{ \frac{1}{36}, \frac{2}{36}, \frac{3}{36}, \frac{4}{36}, \frac{5}{36}, \frac{6}{36}, \frac{5}{36}, \frac{4}{36}, \frac{3}{36}, \frac{2}{36}, \frac{1}{36} \right\}$$

$$H(X|Y) = -\mathbf{p(Y = 2)}[p(x = 1|y = 2)\log_2(p(x = 1|y = 2)) + p(x = 2|y = 2)\log_2(p(x = 2|y = 2)) + \dots] \\ -\mathbf{p(Y = 3)}[p(x = 1|y = 3)\log_2(p(x = 1|y = 3)) + p(x = 2|y = 3)\log_2(p(x = 2|y = 3)) + \dots]$$

...

$$-\mathbf{p(Y = 12)}[p(x = 1|y = 12)\log_2(p(x = 1|y = 12)) + p(x = 2|y = 12)\log_2(p(x = 2|y = 12)) + \dots]$$

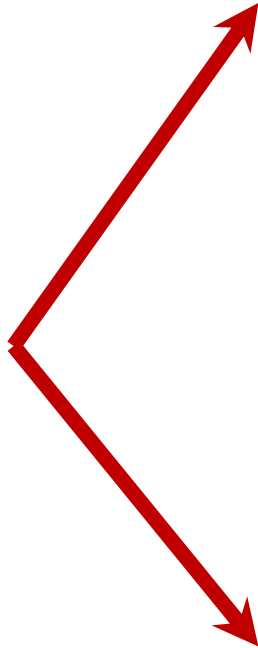
$$H(X|Y) = -\frac{1}{36}[1\log_2 1 + 0 + 0 + 0 + 0 + 0] - \frac{2}{36}\left[\frac{1}{2}\log_2 \frac{1}{2} + \frac{1}{2}\log_2 \frac{1}{2} + 0 + 0 + 0 + 0\right] - \frac{3}{36}\left[\frac{1}{3}\log_2 \frac{1}{3} + \frac{1}{3}\log_2 \frac{1}{3} + \frac{1}{3}\log_2 \frac{1}{3} + 0 + 0 + 0\right] \\ - \dots$$

$$H(X|Y) = 0 + 0,055 + 0,132 + 0,222 + 0,3225 + 0,431 + 0,3225 + 0,222 + 0,132 + 0,055 + 0$$

$$H(X|Y) = 1,894$$

Como $H(X) = -6 \frac{1}{6} \log_2 \frac{1}{6} = 2,585$, hubo traspaso de información de X a Y .

Flujo de Información



DIRECTO: A través de una asignación:
`y := f (x)`

INDIRECTO: La información fluye de x a y **sín** una asignación explícita.

= flujo de comportamiento

```
if (x == 0) :
```

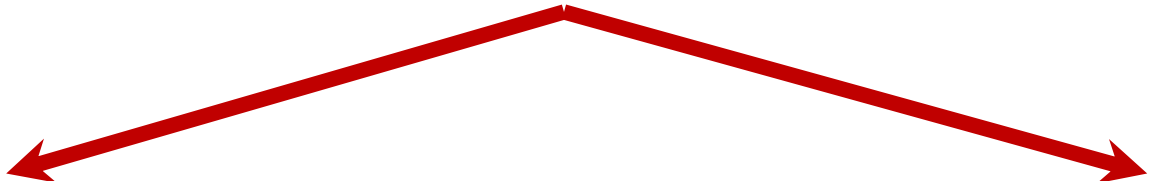
```
    y = 1
```

```
else
```

```
    y = 0
```

Canales Ocultos

Canal que NO fue diseñado para usar en una comunicación



ESPACIAL: Usa atributos de recurso compartido (x ej. archivos, directorios)

TEMPORAL: Usa relación temporal entre los accesos al recurso compartido. (x ej. liberar CPU enseguida o no)

Modelo de interferencia → para detectar canales ocultos

Solución Ideal: AISLAMIENTO TOTAL:

- ⇒ proceso no almacena info
- ⇒ proceso no puede ser observado
- ⇒ proceso no puede comunicar info
- ⇒ **i IMPOSIBLE!** (se comparte CPU, recursos)

Solución: CONFINAMIENTO:

- ⇒ Evita que se filtre info que usuario considera confidencial
- ⇒ es un mecanismo para reforzar el Principio de Mínimo Privilegio = dar a un sujeto sólo los privilegios necesarios para completar su tarea.



Spider Jerusalem
@provocadiarreas

Muchas risas con la seguridad de los 90 pero la información de esos disquetes no podía ser hackeada por un hindú desde la cocina de su casa a medio mundo distancia.



8:21 a. m. · 16 oct. 2025 · 1,2 M Visualizaciones



ClonaCat @gatozepam · 17 oct.
No olvidemos estas joyitas



Para lograr AISLAMIENTO:

(aunque no total, podrían existir canales ocultos)



Virtual Machines: Programa que simula el HW de otro sistema

Sandboxes: Entorno en el cual las acciones de un proceso se restringen de acuerdo a una política de seguridad

Límitan la transferencia de información al controlar las rutas esperadas de movimientos de datos

Capítulos recomendados del libro de Bishop:

- *Capítulo 16 (Flujo de Información)

- *Capítulo 17 (Confinamiento)

- *Capítulo 32 (Entropía) → hay ejemplos y fórmulas.

Recordar: entropía máxima es $1/n$ (siendo n el tamaño del archivo)